

Vulnerability Scanning using Nessus and OpenVas



Project Author:
– Krystian Chrupek ([Linkedin](#))

Warning — Educational Use Only

This project demonstrates the use of **Nessus** and **OpenVAS** to identify security vulnerabilities by comparing the target system against known vulnerability databases.

The vulnerability scanning demonstration shown in this presentation was performed in a fully controlled environment. Targeted systems are owned and managed by the author and used exclusively for testing and learning purposes.

This project **does not intend to:**

- perform unauthorized vulnerability scanning,
- access systems without explicit permission,
- disrupt production or third-party environments,
- violate privacy or data protection laws,
- exploit discovered vulnerabilities for malicious purposes.

Tools such as **Nessus** and **OpenVAS** should be used only on systems, you own or on environments where you have explicit permission to perform security testing. Running vulnerability scans against unauthorized systems may be illegal and may violate local laws and organizational policies.

All actions presented here were carried out at the author's own risk and within a legal, ethical testing scope.

Project Overview:

- *Introduction*
- *Project Requirements*
- *Source and Target*
- *Databases (CVE,CWE,CVSS and NVD)*
- *Introduction about **Nessus***
- *Vulnerability Analysis using Nessus for windows target with security options*
- *Vulnerability Analysis using Nessus for windows target without security options*
- *Vulnerability Analysis , with vs without comparison graph*
- *Introduction about **OpenVAS/GVM***
- *Vulnerability Analysis using OpenVAS/GVM for windows target with security options*
- *Vulnerability Analysis using OpenVAS/GVM for windows target without security options*
- *Vulnerability Analysis, with vs without security options comparison graph*
- *Suggested solutions*
- *Conlusion*
- *References*



Introduction

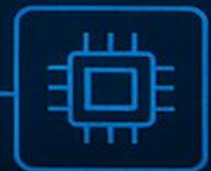
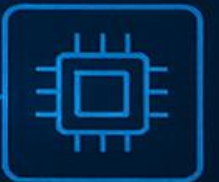
The project is conducted in a fully controlled and authorized environment. Its purpose is strictly educational, focusing on understanding how automated vulnerability scanners identify security weaknesses, misconfigurations, and exposed services in real-world systems.

By performing vulnerability scans against a known and trusted virtualized target, the project aims to provide insight into how such tools are used responsibly in cybersecurity assessments and how their results can be interpreted for defensive and system-hardening purposes.

The project will:

- Perform vulnerability scans using automated security scanning tools (Nessus and OpenVAS/GVM) to assess the security posture of both a Windows Server 2022 virtual machine and a local PC.
- Execute scans from different source, target perspectives (internal and external) to observe how scan results vary depending on the scanning origin.
- Compare scan results between secured and reduced-security configurations of the tested systems.
- Demonstrate how vulnerability scanning results can support system hardening, configuration improvements, and risk reduction in real-world environments.

The output of this project will be presented as a clear and structured report, including screenshots of scan configurations, results, and selected findings, highlighting the **impact of security settings on vulnerability scan outcomes**.



Requirements

To complete this project, the following components are required:

Virtualization & Environment

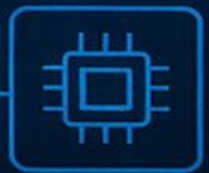
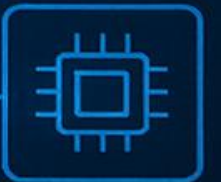
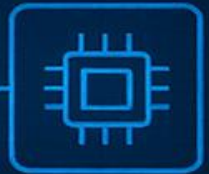
- **Local PC (Host system)** — physical machine running OpenVAS / GVM and participating in vulnerability scans
- **Oracle VirtualBox** — used to host and isolate the Windows Server 2022 virtual machine
- **Windows Server 2022 (VM)** — target system for OpenVAS scans and source system for Nessus scans

Vulnerability Scanning Tools

- **Nessus Essentials** — installed on the Windows Server 2022 virtual machine, used to scan the local PC
- **OpenVAS / Greenbone Vulnerability Manager (GVM)** — installed on the local PC, used to scan the Windows Server 2022 virtual machine

Network & Configuration

- **Internal / Host-Only network** — enables controlled communication between the local PC and the virtual machine
- **Administrative access to both systems** — required for configuration changes and security hardening
- **Isolated test environment** — ensures safe and authorized vulnerability testing



Test Environment – Source and Target System

Nessus Scan Setup:

Source system: Windows Server 2022 running in **Oracle VirtualBox**

- IP address: **192.168.1.26**

Target system: Local PC

- IP address: **192.168.1.15**

Scan type: Advanced Scan

OpenVAS / GVM Scan Setup:

Source system: Local PC

- IP address: **192.168.1.15**

Target system: Windows Server 2022 running in **Oracle VirtualBox**

- IP address: **192.168.1.26**

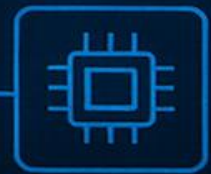
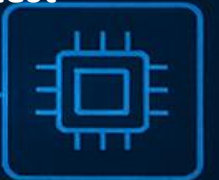
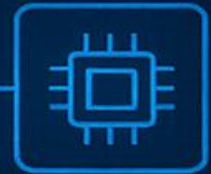
Security Configuration for Testing

For the purpose of this demonstration, selected built-in Windows security features are **intentionally disabled during specific test phases** to observe their impact on scan results. These include:

- **Windows Defender Antivirus** (real-time protection)
- **Firewall & Network Protection**
- **App & Browser Control** (SmartScreen)

Scans are executed twice:

- **Security ON** – default, hardened configuration
- **Security OFF** – reduced protection to highlight differences in detected findings



Databases: CVE,CWE,CVSS,NVD

CVE (Common Vulnerabilities and Exposures)

CVE is a standardized system for identifying publicly known cybersecurity vulnerabilities. Each vulnerability is assigned a unique CVE ID, which allows security tools and professionals to reference and track the same issue consistently across different platforms.

CWE (Common Weakness Enumeration)

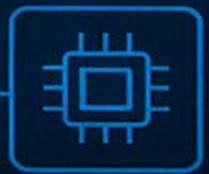
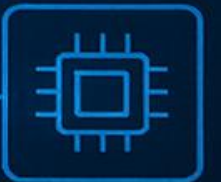
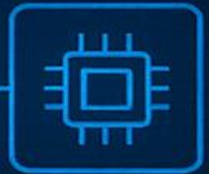
CWE is a classification system that describes common types of software and hardware weaknesses. It focuses on underlying design and implementation flaws that can lead to vulnerabilities, helping developers and security analysts understand root causes.

CVSS (Common Vulnerability Scoring System)

CVSS is a standardized framework used to assess the severity of vulnerabilities. It assigns a numerical score based on factors such as exploitability, impact, and complexity, helping prioritize remediation efforts.

NVD (National Vulnerability Database)

The NVD is a comprehensive U.S. government-maintained database that builds upon CVE data. It enriches vulnerabilities with CVSS scores, CWE classifications, impact metrics, and additional technical details used by tools like Nessus and OpenVAS.



Nessus

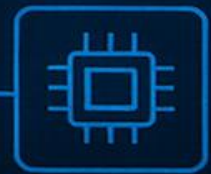
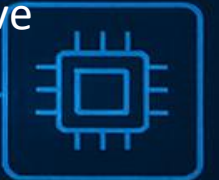
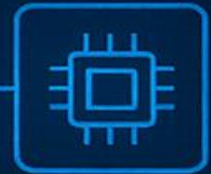
Nessus is a widely used vulnerability assessment tool developed by **Tenable** that is designed to identify security vulnerabilities, misconfigurations, and compliance issues in computer systems and networks.

It performs automated scans using an extensive and frequently updated plugin database based on standards such as **CVE, CVSS, CWE, and the NVD**.

Key Features:

- Performs automated **vulnerability scanning** using a large and frequently updated plugin database.
- Detects vulnerabilities based on industry standards such as **CVE, CVSS, CWE, and the NVD**.
- Supports both **unauthenticated and authenticated (credentialed) scans** for deeper system analysis.
- Identifies open ports, running services, software versions, and missing security patches.
- Assigns **severity scores and risk levels**, helping prioritize remediation efforts.
- Provides detailed and well-structured **scan reports** suitable for analysis and documentation.

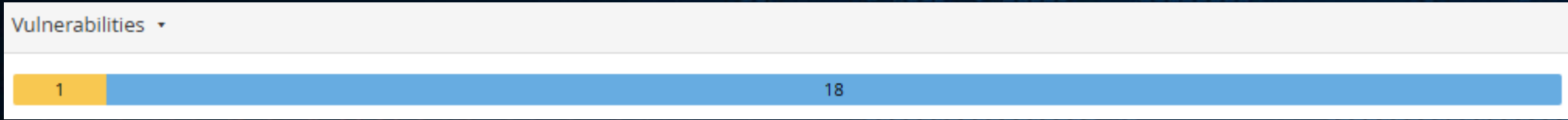
Nessus is commonly used in **defensive cybersecurity**, vulnerability management, and security auditing to improve system hardening and reduce attack surfaces.



Vulnerability Analysis using **Nessus**



Vulnerability Analysis with windows security options turned **ON**



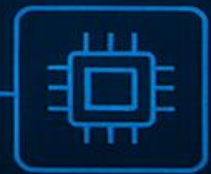
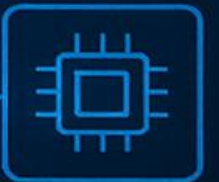
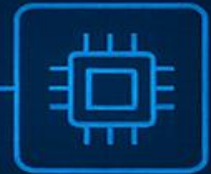
Low (1)

ICMP Timestamp Request – Remote Date Disclosure

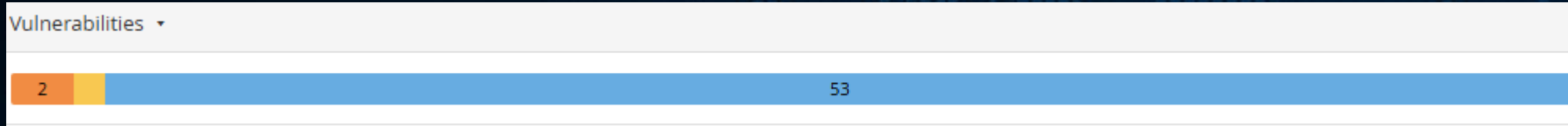
- System responds to ICMP timestamp requests
- Allows remote disclosure of the system time
- Can assist in basic host fingerprinting

Info (18)

- **Asset & OS Identification** – detected operating system and device type
- **Network & Service Enumeration** – basic service and RPC discovery
- **Network Metadata** – MAC address and vendor identification
- **Connectivity & Routing** – traceroute and TCP/IP timestamp information
- **Scan Metadata** – Nessus scan and SYN scanner details



Vulnerability Analysis with windows security options turned **OFF**



Medium (2)

SMB Signing Not Required

- SMB traffic is not cryptographically signed, which allows **Man-in-the-Middle (MITM)** attacks and message tampering.

SSL Certificate Cannot Be Trusted

- The SSL certificate is self-signed or untrusted, enabling **traffic interception** and spoofing attacks.

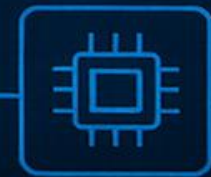
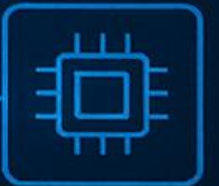
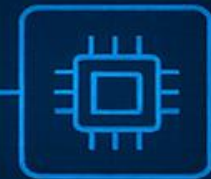
Low (1)

ICMP Timestamp Request – Remote Date Disclosure

- The system responds to ICMP timestamp requests, revealing the remote system time and supporting basic **host fingerprinting**

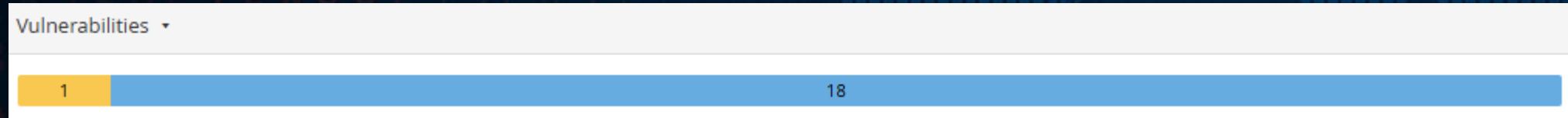
Info (53)

- **Asset & OS Identification** – detected operating system and device type
- **Network & Service Enumeration** – basic service and RPC discovery
- **Network Metadata** – MAC address and vendor identification
- **Connectivity & Routing** – traceroute and TCP/IP timestamp information
- **Scan Metadata** – Nessus scan and SYN scanner details

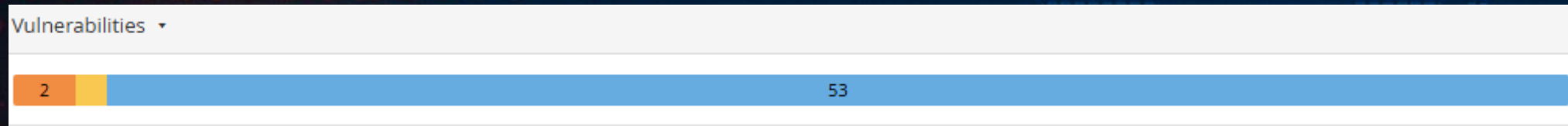


Comparison Graph

With Security options turned **ON**



With Security options turned **OFF**

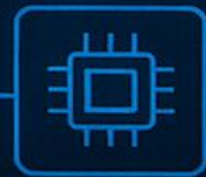
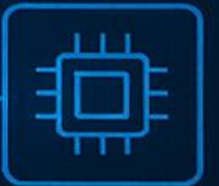
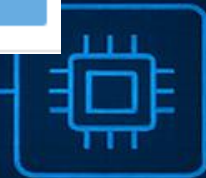


ON vs **OFF**

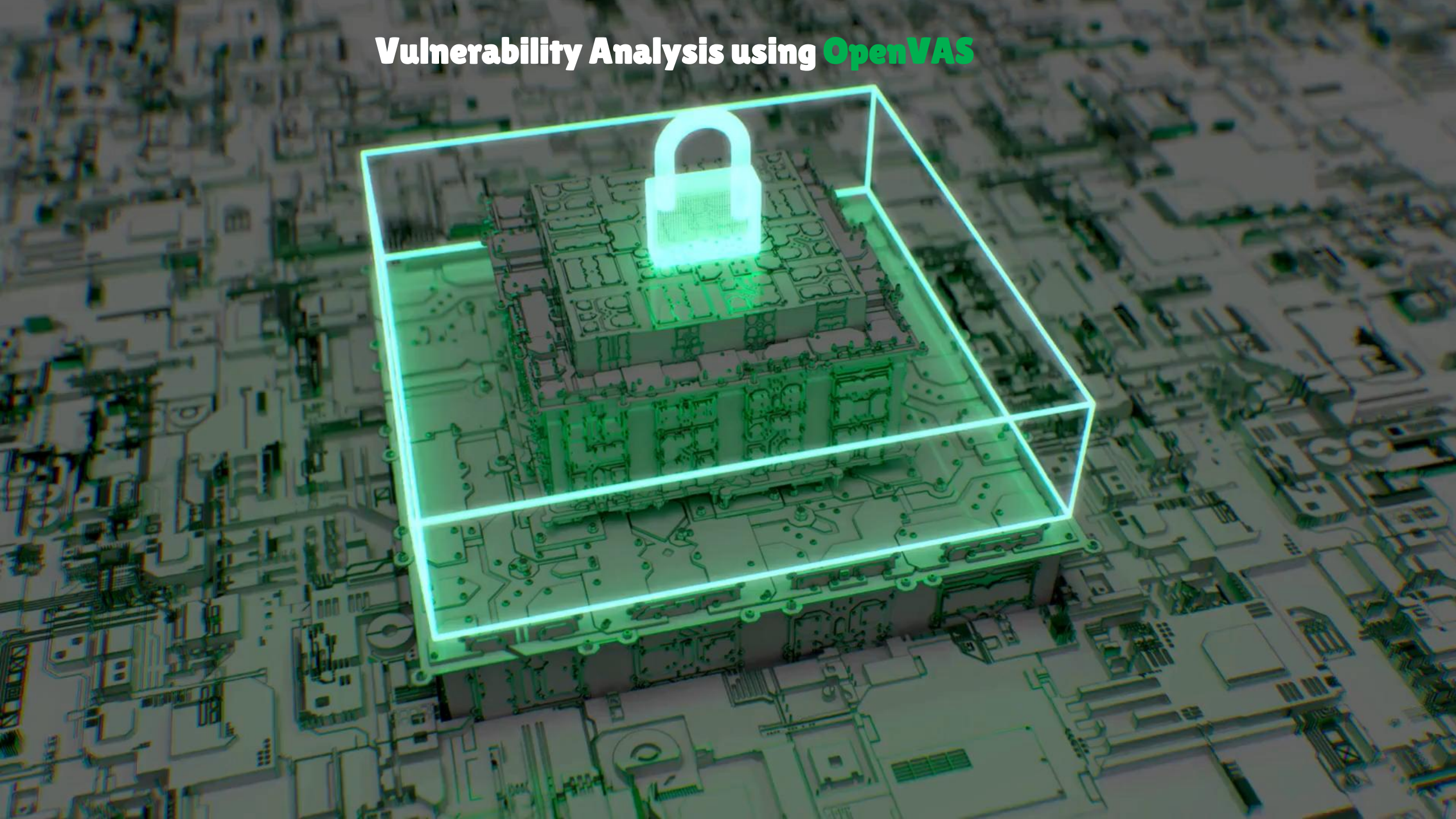
Medium: 0 2

Low: 0 1

Info: 18 53



Vulnerability Analysis using **OpenVAS**



OpenVAS (Greenbone Vulnerability Management)

OpenVAS (Open Vulnerability Assessment System) is an **open-source vulnerability scanning tool** that is part of the **Greenbone Vulnerability Management (GVM)** framework.

What is OpenVAS used for?

- identify **security vulnerabilities** in operating systems, servers, and network services
- detect **misconfigurations**, outdated software, and exposed network services
- assess the **overall security posture** of IT infrastructure

Key features

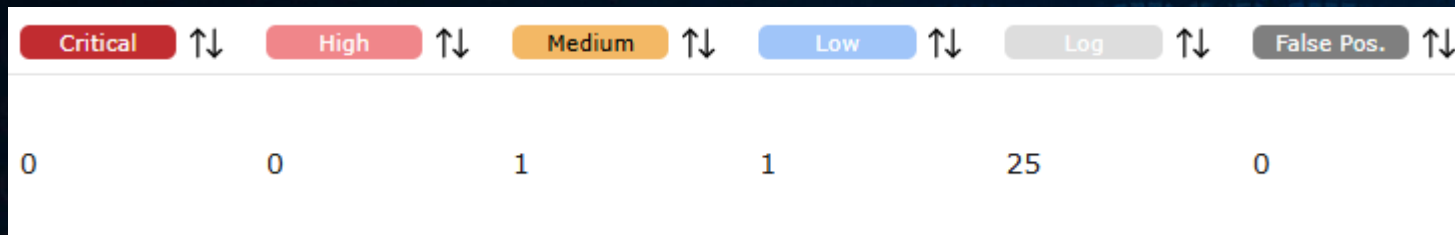
- extensive vulnerability database (NVTs – Network Vulnerability Tests)
- automated and authenticated vulnerability scanning
- detailed reports with severity ratings (CVSS)

Typical use cases

- security audits and penetration testing preparation
- network and system security assessments
- continuous monitoring of infrastructure security



Vulnerability Analysis with Windows Security options turned **ON**



Medium Severity (1)

DCE/RPC and MSRPC Services Enumeration Reporting (Port 135/TCP)

- Indicates that Windows RPC services are accessible and can be enumerated.
- Common in Windows environments, but may increase the attack surface if not properly restricted.
- Risk mainly related to **service exposure**, not an active exploit.

Low Severity (1)

TCP Timestamps Information Disclosure

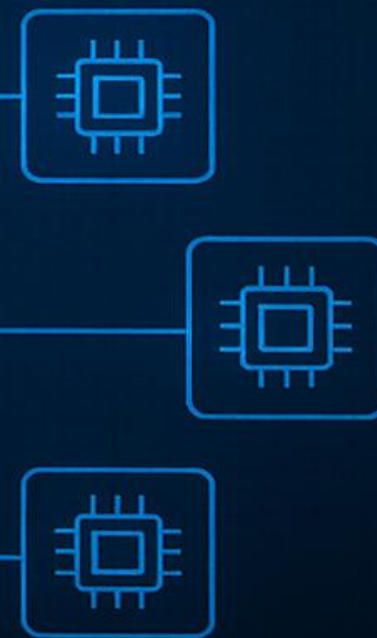
- Reveals system timing information via TCP timestamps.
- Can assist attackers in OS fingerprinting and uptime estimation.
- Low impact on its own, but relevant in advanced attack scenarios.

Log / Informational Findings (25)

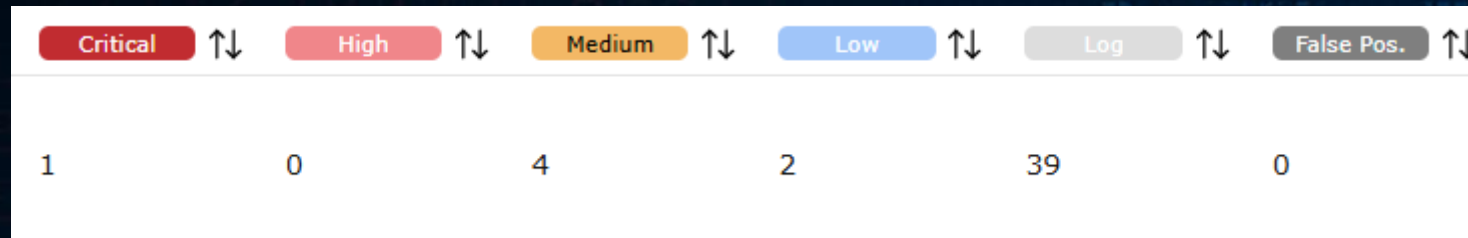
(Log severity = no direct vulnerability, informational only)

- **OS and Service Detection** – operating system and running services were identified.
- **SMB / CIFS Detection** – SMB services are present and responding.
- **HTTP Banner Enumeration** – web server headers and metadata exposed.
- **Web Application Scanning (Info)** – basic application structure detected.
- **Hostname and DNS Detection** – network naming information identified.

These findings **do not represent vulnerabilities**, but show what information is visible to a potential attacker during reconnaissance.



Vulnerability Analysis with *Windows Security* options turned **OFF**



Critical Severity (1)

Discard Service (TCP)

- Legacy diagnostic service exposed, rarely required
- Can be abused for reconnaissance and DoS-style attacks

Medium Severity (4)

Chargen Service Detection (TCP) + Echo Service Reporting (TCP/UDP)

- Unnecessary legacy services increase attack surface
- Should be disabled on modern systems

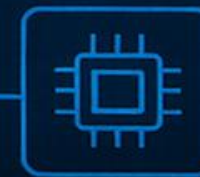
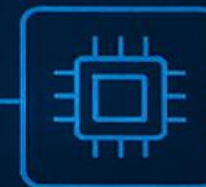
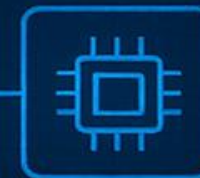
Low Severity (2)

TCP Timestamps Information Disclosure + ICMP Timestamp Reply Disclosure

- Allows system fingerprinting and uptime estimation
- Low impact but useful during reconnaissance

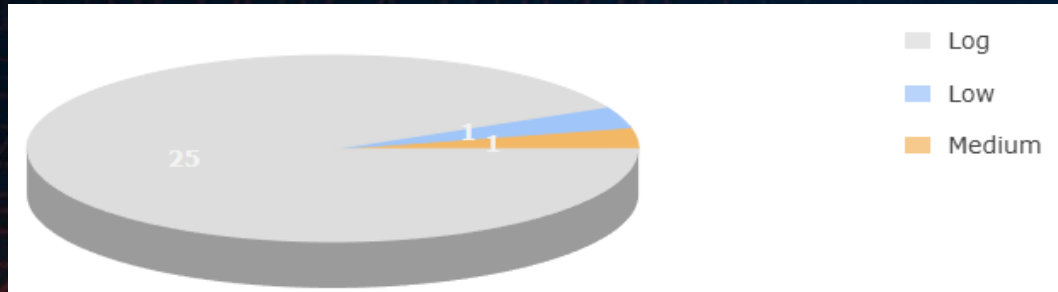
Log (Informational) (39)

- HTTP Server Type & Version – reveals software details
- IIS Detection – identifies web platform
- DNS Server Detection – confirms exposed network service
- Service Detection (GET/HELP) – services respond to generic queries
- CPE Inventory – maps software to known CVEs

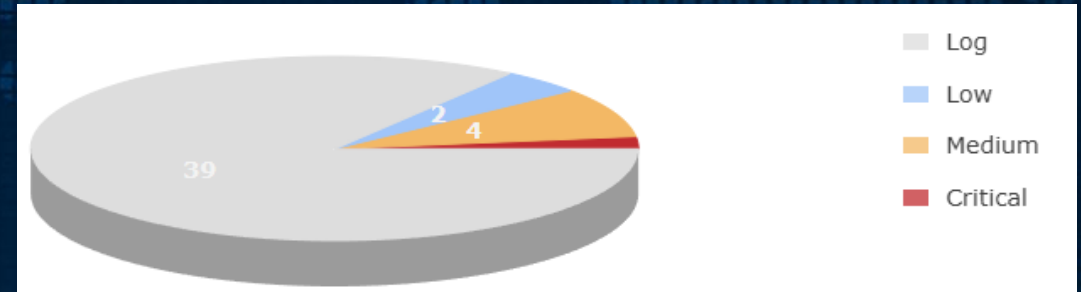


Comparison Graph

With Security options turned **ON**



With Security options turned **OFF**



	ON	VS	OFF
Critical:	0		1
Medium:	1		4
Low:	1		2
Log:	25		39



Suggested solutions:

Critical / Medium Findings

Discard Service (TCP)

- Disable the service or block TCP port **9** on the firewall
- Remove legacy diagnostic services if not required

Chargen Service (TCP/UDP) & Echo Service

- Disable **Chargen (port 19)** and **Echo (port 7)**
- Block services at host and network firewall level

SMB Signing Not Required

- Enable **SMB signing** via Group Policy
- Disable **SMBv1** if still enabled

SSL Certificate Cannot Be Trusted

- Replace self-signed certificates with **CA-trusted certificates**
- Enforce **TLS 1.2 / TLS 1.3** only

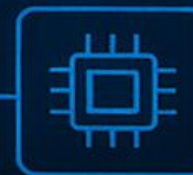
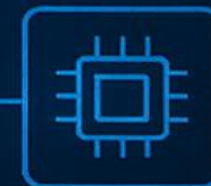
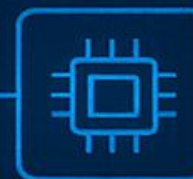
Low Severity Findings

ICMP Timestamp & TCP Timestamp Disclosure

- Disable ICMP timestamp responses
- Disable TCP timestamps where possible

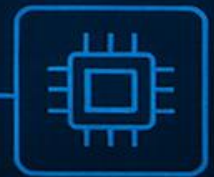
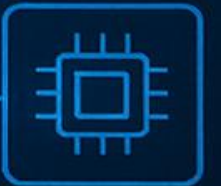
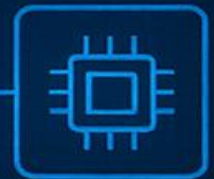
Informational / Hardening Recommendations

- Apply latest **Windows Updates & security patches**
- Disable unused **legacy services**
- Restrict unnecessary **network service exposure**
- Use **host-based firewall** with strict inbound rules
- Enable **security logging & monitoring**



Conclusion

- Disabling Windows security options significantly increases the attack surface of the system.
- Multiple legacy and insecure services (e.g. SMB without signing, CHARGEN, ECHO, DISCARD) become exposed and can be abused for MITM, reconnaissance, and DoS-style attacks.
- Weak or untrusted SSL/TLS configuration allows traffic interception and reduces communication security.
- Most findings are preventable through proper system hardening, not software vulnerabilities.
- Re-enabling security features and applying basic hardening best practices drastically reduces detected risks.



References:

Tenable. *Nessus User Guide*: [GUIDE](#)

MetBrains – Cybersecurity Training Platform:

- *Vulnerability Assessment – Day 2*: Nessus installation, configuration, and vulnerability scanning labs.
- *Vulnerability Assessment – Day 3*: OpenVAS / GVM installation, configuration, and comparative vulnerability scanning labs.

